

GlobalHire AI

Resumo Executivo de Fluxo de Dados para Revisão Jurídica

Documento preparado para envio ao advogado responsável por LGPD, privacidade, termos de uso e contratos com fornecedores.

Data	2026-05-12
Domínio	https://www.globalhireai.com.br
Escopo	Fluxo de dados, fornecedores, riscos e dúvidas jurídicas prioritárias.

A GlobalHire AI é uma plataforma SaaS com inteligência artificial para criação, otimização e análise de documentos profissionais. O usuário pode colar ou enviar currículo em PDF/DOCX, inserir descrição de vaga e gerar:

- currículo ATS;
- carta de apresentação;
- resumo de LinkedIn;
- mensagem para recrutador;
- preparação para entrevista;
- tradução/adaptação de currículo;
- análise ATS Score e palavras-chave.

A aplicação usa Next.js/Vercel no frontend e backend, Supabase para autenticação e banco, Stripe para pagamentos, Groq como provedor de IA, Google OAuth para login social, Cloudflare Turnstile para captcha, e ferramentas de analytics como GA4, Microsoft Clarity e PostHog.

O principal tratamento de dados ocorre porque a plataforma recebe currículos, experiências profissionais, formação, competências, descrições de vagas e documentos gerados por IA. Esses dados podem conter informações pessoais e, eventualmente, dados sensíveis inseridos voluntariamente pelo usuário.

2. Fornecedores e subprocessadores

Fornecedor	Uso	Dados envolvidos
Supabase	Autenticação, banco de dados, sessão e admin API	Nome, e-mail, usuário Auth, perfis, assinaturas, currículos, descrições de vaga, documentos gerados, rate limits
Vercel	Hospedagem e execução serverless	Requisições, IP, user-agent, logs técnicos e dados processados em runtime
Stripe	Checkout, assinatura, Customer Portal e webhooks	E-mail, plano, customer ID, subscription ID, status, price ID e dados de pagamento tratados diretamente pela Stripe
Groq	IA generativa/LLM	Currículo/base profissional, descrição de vaga, parâmetros da tarefa e resultado gerado
Google OAuth	Login social	E-mail, identificador Google e metadados autorizados
Google Analytics 4	Analytics de uso	Eventos sanitizados, page views e identificadores técnicos após consentimento
Microsoft Clarity	UX analytics/heatmap	Dados comportamentais e técnicos após consentimento, com campos sensíveis mascarados
PostHog	Product analytics	Eventos sanitizados e identificador anônimo após consentimento
Cloudflare Turnstile	Captcha/anti-bot	Token captcha, IP e dados técnicos de validação
Cloudflare DNS/Email Routing	Infraestrutura de domínio e possível roteamento de e-mail	Dados técnicos de DNS/tráfego e metadados de e-mail se ativado
Sentry	Monitoramento preparado, mas não identificado como ativo no código	DSN/envs existem; validar se será ativado e configurar filtros de PII

3. Dados coletados e tratados

Dados cadastrais e de autenticação

- nome;
- e-mail;
- senha tratada pelo Supabase Auth;
- dados de login social via Google OAuth;
- cookies/sessão Supabase.

Finalidade provável: autenticação, criação de conta, segurança e execução do serviço.

Dados profissionais

- currículo;
- experiências profissionais;
- formação;
- competências;
- certificações;
- idiomas;
- informações de carreira;
- descrição de vagas;
- documentos gerados por IA.

Finalidade provável: geração, otimização, análise ATS, histórico e regeneração de documentos.

Observação: o sistema armazena currículo, descrição da vaga e documento gerado na tabela `generations` para permitir histórico e regeneração.

Dados de assinatura e cobrança

- plano contratado;
- status da assinatura;
- Stripe customer ID;
- Stripe subscription ID;
- Stripe price ID;
- período de vigência;
- cancelamento ao fim do período.

Dados de cartão/pagamento são tratados diretamente pela Stripe, não pelo app.

Dados técnicos, segurança e analytics

- IP;
- Origin/Referer;
- user-agent e navegador, quando disponíveis por fornecedor;
- token Turnstile;
- rate limit por usuário/IP;
- eventos de analytics;
- identificador anônimo local para analytics;

- logs técnicos de erro e operação.

Analytics só deve carregar após consentimento. O código possui sanitização para não enviar currículo, vaga, e-mail, telefone, endereço, senha, token ou conteúdo gerado para GA4/PostHog/Clarity.

4. Principais riscos identificados

1. Currículos e documentos profissionais são dados de alto impacto para privacidade.

O app armazena currículo, descrição de vaga e output da IA no Supabase. É necessário definir política clara de retenção, exclusão, portabilidade e finalidade.

2. Envio de dados profissionais para Groq.

Currículos e descrições de vaga são enviados ao provedor de IA para geração. É necessário validar contrato, DPA, retenção, uso para treinamento e transferência internacional.

3. Possível inserção voluntária de dados sensíveis.

Currículos podem conter foto, endereço, dados de saúde, nacionalidade, estado civil, documentos ou outras informações desnecessárias. A política deve orientar o usuário a não enviar dados sensíveis não necessários.

4. Retenção automática ainda não está operacional.

Existem variáveis e documentação para retenção, mas o cleanup automático não foi identificado como ativo. Hoje a exclusão ocorre por exclusão granular ou exclusão de conta.

5. Logs técnicos podem conter metadados pessoais.

O upload registra nome de arquivo, tipo, tamanho e erros. Nome de arquivo pode conter nome completo do usuário. Recomenda-se mascarar ou minimizar.

6. RLS e autorização exigem validação no banco real.

O schema possui RLS, mas é recomendável confirmar no Supabase de produção se policies, constraints e triggers estão exatamente aplicadas.

7. Clarity/analytics exigem validação prática.

O código mascara campos sensíveis e só carrega analytics após consentimento, mas deve-se validar em produção que Clarity não captura currículo, vaga ou documentos gerados.

8. Exclusão de conta não remove dados retidos por fornecedores externos.

A rota remove dados do app e tenta remover usuário Supabase Auth, mas Stripe, Google, analytics, Vercel e logs podem reter dados conforme suas próprias políticas.

9. Transferência internacional provável.

Supabase, Vercel, Stripe, Google, Microsoft, PostHog, Cloudflare e Groq podem processar dados fora do Brasil. Contratos e DPAs devem ser revisados.

5. Dúvidas que precisam de validação jurídica

1. Qual base legal será adotada para tratar currículo, descrição de vaga e documentos gerados: execução de contrato, consentimento, legítimo interesse ou combinação?
2. Como tratar juridicamente currículos que contenham dados sensíveis inseridos voluntariamente pelo usuário?
3. O envio de currículo e vaga para a Groq exige consentimento específico, cláusula destacada ou apenas transparência na Política de Privacidade?
4. Qual prazo de retenção adequado para:

- currículos enviados;
 - descrições de vaga;
 - documentos gerados;
 - logs técnicos;
 - dados de assinatura;
 - analytics?
5. A plataforma deve oferecer exportação completa de dados pessoais para portabilidade LGPD além de copiar/baixar documentos?
 6. Como explicar corretamente que a otimização ATS e a IA não garantem entrevista, emprego, contratação ou aprovação em processos seletivos?
 7. Quais subprocessadores devem constar formalmente na Política de Privacidade e em eventual DPA?
 8. É necessário obter consentimento separado para analytics, Clarity/heatmap e PostHog, além do banner atual?
 9. Como documentar transferências internacionais de dados considerando Supabase, Vercel, Stripe, Google, Microsoft, PostHog, Cloudflare e Groq?
 10. Qual procedimento jurídico-operacional deve ser adotado para solicitações de titular: acesso, correção, exclusão, revogação de consentimento e portabilidade?
 11. Quais cláusulas devem constar nos Termos de Uso sobre responsabilidade por conteúdo gerado por IA, revisão pelo usuário e uso profissional dos documentos?
 12. A política de reembolso/cancelamento precisa seguir regra específica do CDC para serviço digital recorrente com Stripe?
 13. É necessário nomear formalmente encarregado/DPO ou indicar canal de privacidade como `privacy@globalhireai.com.br` é suficiente neste estágio?

Anexos técnicos recomendados

Para análise completa, recomenda-se enviar também:

- `docs/legal/data-flow-map.md`;
- `supabase/schema.sql`;
- `.env.example`;
- Política de Privacidade atual;
- Termos de Uso atuais;
- prints ou exports das configurações reais de Supabase, Stripe, Google OAuth, Cloudflare, Groq, GA4, Clarity, PostHog e Vercel.